

STAGE 4

Setting paths:

```
cd /home/user01/springboot-25-log4j-structural/spring-boot-v2.5.0
```

```
MODULE_DIR="spring-boot-tests/spring-boot-smoke-tests/spring-boot-smoke-test-actuator-log4j2"
```

```
R="$PWD/reports_stage4_springboot"
```

```
RULES="$R/rules"
```

```
mkdir -p "$R" "$RULES"
```

Rules:

```
cat > "$RULES/springboot-log4shell-taint.yml" <<'EOF'
```

```
rules:
```

```
- id: springboot-user-input-to-logger
```

```
  mode: taint
```

```
  languages:
```

```
    - java
```

```
  message: "User-controlled input may flow into a logging call."
```

```
  severity: WARNING
```

```
pattern-sources:
```

```
- pattern: $REQ.getHeader(...)
```

```
- pattern: $REQ.getParameter(...)
```

```
- pattern: $REQ.getQueryString()
```

```
- pattern: $REQ.getRequestURI()
```

```
- pattern: $REQ.getRequestURL()
```

- pattern: \$REQ.getRemoteAddr()
- pattern: \$REQ.getRemoteHost()
- pattern: \$REQ.getUserPrincipal()
- pattern: \$REQ.getCookies()
- pattern: \$REQ.getReader()
- pattern: \$REQ.getInputStream()

- patterns:

- pattern-inside: |

```
$RET $METHOD(..., @RequestParam(...) $TYPE $PARAM, ...) {
    ...
}
```

- pattern: \$PARAM

- patterns:

- pattern-inside: |

```
$RET $METHOD(..., @RequestHeader(...) $TYPE $PARAM, ...) {
    ...
}
```

- pattern: \$PARAM

- patterns:

- pattern-inside: |

```
$RET $METHOD(..., @PathVariable(...) $TYPE $PARAM, ...) {
    ...
}
```

- pattern: \$PARAM

- patterns:

- pattern-inside: |

- \$RET \$METHOD(..., @RequestBody \$TYPE \$PARAM, ...) {

- ...

- }

- pattern: \$PARAM

pattern-sinks:

- pattern: \$LOG.trace(...)

- pattern: \$LOG.debug(...)

- pattern: \$LOG.info(...)

- pattern: \$LOG.warn(...)

- pattern: \$LOG.error(...)

- pattern: \$LOG.fatal(...)

EOF

Run semgrep :

semgrep scan \

--config "\$RULES/springboot-log4shell-taint.yml" \

--json \

--output "\$R/semgrep-springboot-taint.json" \

"\$MODULE_DIR"

jq '.results | length' "\$R/semgrep-springboot-taint.json" \

```
| tee "$R/semgrep-springboot-taint-count.txt"
```

```
jq -r '
```

```
.results[]?
```

```
| [
```

```
.check_id,
```

```
.path,
```

```
.start.line,
```

```
.end.line,
```

```
.extra.message
```

```
]
```

```
| @tsv
```

```
' "$R/semgrep-springboot-taint.json" \
```

```
| tee "$R/semgrep-springboot-taint-summary.tsv"
```

Grep support check:

```
grep -RInE \
```

```
"getHeader|getParameter|getQueryString|getRequestURI|getRequestURL|@RequestParam  
|@RequestHeader|@PathVariable|@RequestBody" \
```

```
"$MODULE_DIR/src" \
```

```
| tee "$R/springboot-request-source-grep.txt"
```

```
grep -RInE \
```

```
"\\.trace\\(\\.debug\\(\\.info\\(\\.warn\\(\\.error\\(\\LoggerFactory|getLogger" \
```

```
"$MODULE_DIR/src" \
```

```
| tee "$R/springboot-logging-sink-grep.txt"
```